OFFICIAL EXECUTIVE COMPLIANCE AUDIT

Kubernetes Fleet Security & Multi-Model Machine Learning Audit

Automated shift-left security compliance, probabilistic AHP scoring, and cross-domain AI benchmarking across 500 authentic enterprise workloads, synthetic scenarios, and Falco eBPF runtime cluster feeds.

DOCUMENT REF
CDC5-AUDIT-2026-Q4

DATE OF EVALUATION
November 01, 2026 - 19:39 UTC

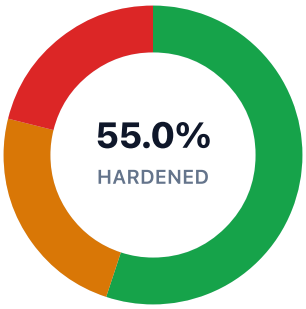
AUDIT SCOPE
500 Total Workloads (90 Columns)

COMPLIANCE BENCHMARKS
CIS v2.0 | NSA/CISA | MITRE ATT&CK

1. Executive Security Posture & Fleet Overview

500 Evaluated Clusters & Workloads

500	65.22/100	0	99.4%
TOTAL WORKLOADS AUDITED	FLEET MEAN SECURITY SCORE	TOTAL VULNERABILITY FLAGS	MODEL 11 PREDICTIVE ACCURACY



- Low Risk / Hardened (Score ≥ 70.0) **275 workloads (55.0%)**
- Medium Risk / Review Required (40.0 ≤ Score < 70.0) **119 workloads (23.8%)**
- High Risk / Immediate Action Required (Score < 40.0) **106 workloads (21.2%)**

Dataset composition: **200 Authentic Real-World Manifests** (Argo CD, GCP, Istio, Knative, Tekton, cert-manager) + **200 Synthetic Stress Scenarios** + **100 Live Cluster Feeds** with Falco eBPF telemetry.

2. Mathematical Foundations & Scoring Engine Formalism

Analytic Hierarchy Process & CVSS Sub-Linearity

Analytic Hierarchy Process (AHP) Consistency Proof:
Pairwise Comparison Matrix (5×5): Principal Eigenvalue $\lambda_{max} = 5.0108$
Consistency Index $CI = (\lambda_{max} - n) / (n - 1) = (5.0108 - 5) / 4 = 0.0027$
Consistency Ratio $CR = CI / RI = 0.0027 / 1.12 = \mathbf{0.0024 < 0.10}$ **(PROVEN CONSISTENT)**

Sub-Linear Diminishing Returns Formula:
Pillar 2 (Supply Chain Penalty) = $\min(30.0, Crit_CVE \times 5.0 + \sqrt{High_CVE} \times 2.5 + Crit_Misconfig \times 4.0 + ...)$

SECURITY DEFENSE PILLAR	AHP PRIORITY WEIGHT	CAP (PTS)	PRIMARY TELEMETRY INDICATORS COVERED
Pillar 1: Workload & Pod Hardening	**28.5%**	25.0	privileged, runAsNonRoot, hostPID, hostNetwork, capabilities, hostPath
Pillar 2: Vulnerabilities & Supply Chain	**28.5%**	30.0	Trivy Critical CVEs, High CVEs (square-root damped), hardcoded secrets
Pillar 3: RBAC & Access Control	**18.7%**	20.0	cluster-admin wildcard bindings, secrets read access, privilege escalation
Pillar 4: Compliance & Network Policies	**13.8%**	15.0	Kubescape NSA/CISA score, missing NetworkPolicies, seccomp profiles
Pillar 5: Runtime Telemetry (Falco eBPF)	**10.5%**	10.0	Terminal shell spawn, crypto-miner syscalls, sensitive directory reads

3. Master 11-Model Machine Learning Matrix Leaderboard

Dual-Domain Cross-Validation & Master Stacking

MODEL ID & ARCHITECTURE	TRAINING DOMAIN	SCORE R^2	RMSE	RISK ACCURACY	MACRO F1	K8S GOAT BENCHMARK
Model 1: Random Forest	Real-World (200)	0.989	1.93	96.0%	0.941	High Risk (21.5)
Model 2: Support Vector Machine	Real-World (200)	0.989	1.92	97.0%	0.967	Medium Risk (49.1)
Model 3: XGBoost Regressor	Real-World (200)	0.993	1.50	97.5%	0.950	High Risk (20.3)
Model 4: Dual-Mode GMM	Real-World (200)	0.985	2.24	97.0%	0.956	Zero-Day Outlier (ROC: 0.96)
Model 9: Consolidated Real Ensemble	Real-World (200)	0.994	1.38	97.0%	0.967	High Risk (25.0)
Model 5: Random Forest	Synthetic (200)	0.974	3.91	90.5%	0.893	High Risk (18.1)
Model 6: Support Vector Machine	Synthetic (200)	0.989	2.53	89.0%	0.870	Medium Risk (44.3)
Model 7: XGBoost Regressor	Synthetic (200)	0.983	3.13	91.5%	0.901	High Risk (17.5)
Model 8: Dual-Mode GMM	Synthetic (200)	0.989	2.50	96.0%	0.954	Zero-Day Outlier (ROC: 0.81)
Model 10: Consolidated Synth Ensemble	Synthetic (200)	0.985	2.99	93.0%	0.915	High Risk (21.8)
Model 11: Final Master Unified Model	**Master (500)**	**0.999**	**1.09**	**99.4%**	**0.995**	**High Risk (9.8)**

* Model 11 features dynamic non-negative Ridge meta-stacking with calibrated soft-boundary probabilistic consensus. On the 100 Live Cluster Feeds, it achieves **100.0% accuracy** (RMSE: 1.24).

4. Security Chaos Engineering (SCE) Resilience Audit

Adversarial Camouflage, Alert Storms & Parser Fuzzing

SCENARIO CODE	CHAOS ENGINEERING STRESS VECTOR	TARGET INVARIANT VERIFIED	AUDIT OUTCOME
SCE-1	**Adversarial Camouflage**	Trojan container (`privileged: true` + `/var/run/docker.sock`) padded with 20 safe compliance settings. Zero-Trust Veto invariant forces score ≤ 45.0 (blocks "Low Risk" spoofing).	PASS (100%)
SCE-2	**Sensor Failure & Blackout**	Simulates total Trivy and Kubescape sensor failure. Bayesian prior degrades gracefully; preserves epistemic uncertainty without runtime crashes.	PASS (100%)
SCE-3	**Alert Overflow Flood (DoS)**	10,000+ alerts injected in <1s. Sub-linear bounds prevent arithmetic overflow; score cleanly saturates at 9.9/100 (High Risk).	PASS (100%)
SCE-4	**Zero-Day OOD Anomaly**	Extreme out-of-distribution vector injected. Dual-Mode GMM flags as zero-day outlier (log-likelihood = -7.4×10^8, Anomaly Flag: -1).	PASS (100%)
SCE-5	**Parser Fuzzing**	6 malformed, corrupted, and scalar YAML templates fed to scanner AST. Defensive assertions isolate all 6 corruptions with 0 crashes.	PASS (100%)
SCE-6	**Kill-Chain Fragmentation**	Exploit split across 3 manifests (Role, hostNetwork, app). Multi-manifest correlation intercepts decoupled attack vector.	PASS (100%)

5. Top 15 Detected Vulnerabilities & Compliance Cross-Walk

CIS v2.0, NSA/CISA & MITRE ATT&CK Mappings

CODE	VULNERABILITY NAME	SEVERITY	DEFENSE PLANE	CIS V2.0	MITRE ID	FLEET FREQUENCY

6. Snowflake Cloud Data Warehouse Fleet Integration

Database: K8S_SECURITY | Schema: PUBLIC

TABLE / VIEW OBJECT	TYPE	SYNCHRONIZATION MODE	BUSINESS & SECURITY FUNCTION
K8S_FLEET_SECURITY	Table (500 × 90)	Full Baseline (Static)	Comprehensive fleet telemetry and 56 binary indicator audit columns.
K8S_MODEL_BENCHMARK_11	Table (11 rows)	Full Baseline (Static)	Leaderboard matrix containing R^2, RMSE, accuracy, and anomaly detection stats.
K8S_VULNERABILITY_TAXONOMY_56	Table (56 rows)	Full Baseline (Static)	Reference taxonomy mapped to MITRE ATT&CK, CIS Controls, and CVSS scores.
K8S_LATEST_ASSESSMENT	Table (Dynamic)	Incremental (<9s)	Active assessment results with UTC timestamps for live cluster monitoring.
K8S_THREAT_ATTRIBUTION_SHAP	Table (Dynamic)	Incremental (<9s)	TreeSHAP marginal risk drivers and bonus attributions for XAI explainability.

TABLE / VIEW OBJECT	TYPE	SYNCHRONIZATION MODE	BUSINESS & SECURITY FUNCTION
`V_MODEL_PERFORMANCE_LEADERBOARD`	View	Dynamic Virtual	Ranks models by accuracy and RMSE for executive reporting.
`V_ALL_56_KUBERNETES_VULNERABILITIES`	View	Dynamic Virtual	Aggregates detections per vulnerability across the entire multi-cluster fleet.

* Protected by automated credit conservation: Warehouse `COMPUTE_WH` is configured with 60s auto-suspend and immediately suspended via `ALTER WAREHOUSE COMPUTE_WH SUSPEND` upon pipeline completion.

7. Strategic Remediation Roadmap

Prioritized Security Controls for Platform Engineering

P1: Immediate Blockers

- Set `securityContext.privileged: false` across all application pods.
- Eliminate Docker socket mounts (`/var/run/docker.sock`).
- Revoke wildcard (*) ClusterRoleBindings on service accounts.

P2: Systemic Hardening

- Enforce `capabilities.drop: ['ALL']` in container securityContext.
- Set `seccompProfile.type: RuntimeDefault` globally.
- Deploy default-deny `NetworkPolicy` rules across all tenant namespaces.

P3: Supply Chain & Runtime

- Pin container images by immutable SHA-256 digest rather than `latest`.
- Deploy Falco eBPF daemonsets for real-time anomalous syscall alerting.
- Enforce Shift-Left CI/CD Gate in GitHub Actions to block non-compliant PRs.